Gazete Atölyesi · Hub Teması

Güvenlik Testi Raporu

Tarih: 15.10.2026 · İncelenen: `hub-theme.ts`, `hub-theme.css`, `main.tsx`, `index.html`, `KURULUM.md`, `AGENTS.md` (rtai-hub-tema, yumuşak tema geçişli sürüm)

Özet. Kritik bir açık bulunmadı: XSS yok, kod veriye dokunmuyor, yeni npm bağımlılığı yok. Tema değeri her yolda yalnızca `"light"` / `"dark"` olarak kabul ediliyor. En dikkat çekici bulgu kodda değil süreçte: paket, ekip bilgisayarlarındaki **Codex'e talimat veren bir depo** olduğu için depoya yazabilen herkes bu talimatları değiştirebilir. Kod tarafında ise **herhangi bir site** editörü gömüp temasını değiştirebiliyor; etkisi yalnızca görünümle sınırlı. Kod bulguları tarayıcıda çalıştırılarak doğrulandı.

Kapsam ve yöntem

- İncelenen dosyalar `github.com/elifnazliozer/rtai-hub-tema` deposunda bu raporla aynı commit'teki sürümdür (yumuşak tema geçişi eklenmiş hâli). Aynı dosyalar editör projesine uygulanmış hâliyle test edildi; testler bu sürümle yeniden çalıştırıldı.
- Kod satır satır incelendi (statik analiz). `innerHTML`, `eval`, `Function()` kullanımı aranıp bulunmadı.
- Editör Vite geliştirme sunucusunda Chromium tarayıcıda çalıştırıldı. `localhost` ile `127.0.0.1` tarayıcı açısından farklı kökenler olduğundan, editör `localhost`'taki "yabancı" bir sayfaya iframe ile gömülerek kökenler arası saldırılar denendi.
- Hub ile aynı kökenden gömme senaryosu, editörü aynı kökenli bir üst sayfaya gömüp Hub'ın `toggleTheme` davranışını taklit ederek test edildi.
- Gerçek radiotedu.com/erp sayfasının sunucu başlıkları (CSP, `X-Frame-Options`) ve editörün sitede nasıl barındırıldığı incelenemedi; bu bilgiler erişilebilir değildi.

Bulgular

#	Önem	Bulgu	Durum
1	**Düşük–Orta**	Depoya yazabilen biri `AGENTS.md` / `KURULUM.md` üzerinden ekipteki Codex'lere zararlı adım uygulatabilir	Süreç riski
2	**Düşük**	Herhangi bir site `postMessage` ile editörün temasını değiştirebiliyor (köken kontrolü yok)	Doğrulandı
3	**Bilgi**	Editörün hangi sitelerce gömülebileceği sınırlanmamış (`frame-ancestors` yok)	Yapılandırma
4	**Bilgi**	Google Fonts: ziyaretçi IP'si Google'a gider; sıkı CSP altında yazı tipi yüklenmez	Gizlilik / Uyumluluk
5	**Bilgi**	Depo herkese açık; commit'te kişisel e-posta adresi görünüyor	Doğrulandı · Gizlilik
6	**Bilgi**	`?theme=` parametresi kullanıcının ve Hub'ın tercihini geçersiz kılıyor	Doğrulandı

Bulgu detayları

1. Codex talimatlarının değiştirilmesi [Düşük–Orta]

`AGENTS.md, KURULUM.md`

- Paket, ekip üyelerinin bilgisayarlarında Codex'in okuyup **uygulayacağı** talimatlar içeriyor. Codex bu talimatlarla dosya değiştiriyor ve `npm ci` / `npm run build` gibi komutlar çalıştırıyor.
- Depoya yazma yetkisi olan biri (ya da ele geçirilmiş bir GitHub hesabı) bu dosyalara, örneğin "şu betiği indirip çalıştır" ya da "şu adrese istek gönder" gibi bir adım ekleyebilir. Bu, depoyu her kullanan ekip üyesinin bilgisayarında çalıştırılabilir (tedarik zinciri / prompt injection).
- Şu anki içerik zararsızdır: yalnızca 2 dosya kopyalama, 2 dosyada birkaç satır değişiklik ve proje içinde test/derleme komutları var.
- Sınırlayan koşullar: Codex onay isteyen modda çalışıyorsa her komut kullanıcıya gösterilir. Depoya şu an yalnızca sahibi yazabiliyor.

2. Yabancı siteden tema değiştirme [Düşük]

`hub-theme.ts:90–93`

- `message` dinleyicisi `event.origin` ve `event.source` değerlerini kontrol etmiyor. Bu, editör farklı bir alan adına taşınırsa Hub'ın tema gönderebilmesi için bilerek bırakıldı.
- Test: editör yabancı kökenli (`localhost`) bir sayfaya gömüldü ve `{type:'radiotedu-theme', theme:'dark'}` gönderildi. Editör koyu moda geçti.
- Etkisi yalnızca görünüm: mesaj sayfada başka hiçbir şeyi değiştiremiyor. Editöre ulaşan 10 bozuk/zararlı mesajın hepsi reddedildi (aşağıya bakınız).
- Bu bulgunun ön koşulu, editörün başka bir siteye gömülebilmesidir (bkz. 3).

3. Gömme sınırı yok [Bilgi]

`Sunucu yapılandırması (docs/DEPLOYMENT.md)`

- Bu, tema paketinden önce de var olan bir durumdur. Editör statik dosyalarla sunuluyor ve `frame-ancestors` belirlenmezse herhangi bir site onu iframe içinde açabilir. Bu, 2. bulgunun ve tıklama tuzağı (clickjacking) türü saldırıların ön koşuludur.
- Gazeteler tarayıcıda kökene göre saklandığı için, yabancı bir site editörü gömse bile kayıtlı gazetelere doğrudan erişemez.

4. Harici yazı tipi [Bilgi]

`index.html:2`

- Albert Sans, `fonts.googleapis.com` ve `fonts.gstatic.com` adreslerinden yükleniyor. Testte sayfanın dışarıya yaptığı tek istekler bu iki adresti. Ziyaretçinin IP adresi Google'a gider; Hub da aynı yazı tipini aynı yerden yüklediği için yeni bir gizlilik etkisi oluşmuyor.
- Google Fonts CSS'i dinamik üretildiği için SRI (bütünlük kontrolü) eklenemiyor. Yüklenen içerik yalnızca CSS ve yazı tipi dosyası, betik değil.
- Sitede `style-src` / `font-src` bu adreslere izin vermeyen bir CSP varsa yazı tipi yüklenmez ve arayüz Arial ile görünür. İşlevsellik bozulmaz.

5. Depo görünürlüğü [Bilgi]

- Depo, GitHub'a giriş yapmadan erişilebilir durumda (API yanıtı 200). İçerikte gizli bilgi yok: şifre, token, API anahtarı ya da iç adres bulunmadı.
- Commit yazarı olarak kişisel e-posta adresi kayıtlı ve herkes görebiliyor.

6. Adres parametresi önceliği [Bilgi]

`hub-theme.ts:34-37, :70-74`

- `?theme=dark` içeren bir bağlantı, kullanıcının Hub'daki seçiminden bağımsız olarak editörü o temada açar ve canlı senkronu kapatır. Test kolaylığı için bilerek eklendi; etkisi yalnızca görünüm.

Sağlam çıkan kısımlar

- **Tema doğrulaması:** `isTheme` (`hub-theme.ts:12`) yalnızca tam olarak `"light"` veya `"dark"` değerlerini kabul ediyor. `<html>` öğesine yazılan değer her zaman bu iki sabitten biri.
- **postMessage ile reddedilenler (10/10):** öznitelik kaçışı (`light" onload="…`), HTML etiketi (`<img onerror>`), dizi (`['light']`), JSON metni, `null`, sayı, `theme` alanı olmayan mesaj, `__proto__` alanlı nesne, büyük harf (`LIGHT`), başında boşluk olan değer (`" light"`). `toString` fonksiyonu içeren bir nesne ise tarayıcı tarafından hiç gönderilemedi (`DataCloneError`), yani editöre ulaşamıyor.
- **Adres parametresi:** `?theme=<img src=x onerror=alert(1)>` yok sayıldı; sayfaya öğe eklenmedi.
- **Tarayıcı hafızası:** `radiotedu_theme` ve `theme` anahtarlarına konan zararlı değerler yok sayıldı. Kod hafızaya hiçbir şey yazmıyor, yalnızca okuyor.
- **Kökenler arası erişim:** Üst sayfa yabancı kökenliyken `window.parent.document` erişimi `try/catch` ile güvenle atlanıyor. Testte konsolda hata oluşmadı.
- **Yumuşak geçiş:** Tema geçişi tarayıcının `document.startViewTransition` özelliğiyle yapılıyor (`hub-theme.ts:22-32`). Yalnızca doğrulanmış tema değeriyle çağrılıyor, sayfa görünür değilse ya da kullanıcı animasyonları azaltmışsa çalışmıyor; desteklemeyen tarayıcıda tema anında değişiyor. Güvenlik açısından yeni bir yüzey eklemiyor.
- **Diğer:** `innerHTML`, `eval` ya da dinamik kod yok. Yeni npm bağımlılığı yok. Gazete verilerine, kayıt/aktarım koduna ve baskı çıktısına dokunulmuyor. CSS dosyası yalnızca renk ve yazı tipi değiştiriyor.

Önerilen düzeltmeler

```
// [2] Tema mesajını yalnızca Hub'dan ve yalnızca üst pencereden kabul et (hub-theme.ts)
const HUB_ORIGINS = ['https://radiotedu.com', 'https://www.radiotedu.com'];
window.addEventListener('message', (event) => {
  if (event.source !== window.parent || !HUB_ORIGINS.includes(event.origin)) return;
  const data = event.data as { type?: unknown; theme?: unknown } | null;
  if (data && data.type === MESSAGE_TYPE && isTheme(data.theme)) apply(data.theme);
});

# [3] Editörü sunan sunucuda (Apache .htaccess örneği)
Header always set Content-Security-Policy "frame-ancestors 'self' https://radiotedu.com
https://www.radiotedu.com"

# [1] GitHub: Settings → Branches → main için koruma kuralı (doğrudan push yok, PR + onay)
#     Ekibe sabit bir sürüm verin; Codex'e şunu yazın:
#     "rtai-hub-tema deposunun <commit> sürümündeki KURULUM.md'yi uygula, her komuttan önce onay iste"
#     Siteye yüklemeden önce editördeki değişiklikleri kontrol edin: 2 yeni dosya + main.tsx +
index.html

// [4] İsteğe bağlı: yazı tipini sitenin kendisinden sunun (Google'a istek gitmez)
//     woff2 dosyalarını public/fonts/ altına koyup @font-face ile tanımlayın, index.html'deki
//     fonts.googleapis.com bağlantılarını kaldırın.

# [5] GitHub: Settings → Emails → "Keep my email addresses private"
git config user.email "<kullanıcı-id>+elifnazliozer@users.noreply.github.com"
```

Öncelik: önce 1 (depo yazma koruması ve sabit sürüm), sonra 2 ve 3 birlikte (köken kontrolü ve `frame-ancestors`), ardından isteğe bağlı olarak 5 ve 4.